
Module 7 – Remediation Advisory Pack

Finding 1 – Public Storage Bucket

Severity: Critical

Risk

The storage bucket is publicly accessible, allowing unauthorized users to access sensitive data.

Remediation

- Enable **Block Public Access**
- Remove public bucket policies/ACLs
- Enable KMS encryption
- Enable versioning and access logging

Terraform

```
resource "aws_s3_bucket_public_access_block" "bucket" {  
    bucket = aws_s3_bucket.data.id  
  
    block_public_acls    = true  
    block_public_policy  = true  
    ignore_public_acls   = true  
    restrict_public_buckets = true  
}
```

Evidence

- Public access disabled
- Checkov/tfsec passes
- Security Hub finding resolved

Finding 2 – Wildcard IAM Policy

Severity: Critical

Risk

A wildcard IAM policy (*:*) gives excessive permissions. If compromised, an attacker could gain full control of cloud resources.

Remediation

- Remove wildcard permissions
- Apply least-privilege IAM roles
- Use OIDC instead of long-lived access keys

Terraform

```
Action = [  
  "s3:GetObject",  
  "s3:PutObject",  
  "ec2:DescribeInstances"  
]
```

Evidence

- No "Action": "*" in IAM policy
- IAM Access Analyzer reports no excessive permissions
- CI/CD pipeline functions successfully

Finding 3 – Public Database

Severity: Critical

Risk

A publicly accessible database without encryption increases the risk of unauthorized access and data exposure.

Remediation

- Deploy database in a private subnet
- Disable public access
- Enable KMS encryption
- Enable backups and deletion protection

Terraform

```
publicly_accessible = false
```

storage_encrypted = true

backup_retention_period = 30

deletion_protection = true

Evidence

- Database is private
- Encryption enabled
- Automated backups configured
- Checkov/tfsec scans pass

Remediation Summary

Finding	Priority	Success Criteria
Public Storage Bucket	P1	Public access blocked, encryption enabled
Wildcard IAM Policy	P1	Least-privilege IAM implemented
Public Database	P1	Private, encrypted, backups enabled